HAL open science

State-of-the-Art: Secure-Channel Establishment in Constrained Mobile Environments and Lawful Interception

Elsa López Pérez, Cristina Onete, Clément Papon, Mališa Vučinić

▶ **To cite this version:**

Elsa López Pérez, Cristina Onete, Clément Papon, Mališa Vučinić. State-of-the-Art: Secure-Channel Establishment in Constrained Mobile Environments and Lawful Interception. L3.1, Inria; Université de limoges. 2026. hal-05450526

HAL Id: hal-05450526

https://hal.science/hal-05450526v1

Submitted on 9 Jan 2026

HAL is a multi-disciplinary open access archive for the deposit and dissemination of scientific research documents, whether they are published or not. The documents may come from teaching and research institutions in France or abroad, or from public or private research centers.

L'archive ouverte pluridisciplinaire **HAL**, est destinée au dépôt et à la diffusion de documents scientifiques de niveau recherche, publiés ou non, émanant des établissements d'enseignement et de recherche français ou étrangers, des laboratoires publics ou privés.

Distributed under a Creative Commons CC BY-NC-ND 4.0 - Attribution - Non-commercial use - No Derivative Works - International License

NF-HiSec

Network of the Future - End-to-end Security

State-of-the-Art: Secure-Channel Establishment in Constrained Mobile Environments and Lawful Interception

Identifiant projet	ANR-22-PEFT-0009
Acronyme projet	NF-HiSec
Nom du projet	Network of the Future - End-to-end Security
Numéro du livrable	D3.1
Titre du livrable	State-of-the-Art: Secure-Channel Establishment in Constrained Mobile Environments and Lawful Interception
Date prévue	15 December 2025
Date de soumission	January 9, 2026
Editors	Cristina ONETE (XLIM), Mališa VUČINIĆ (Inria (AIO))
Contributors	Elsa LÓPEZ PÉREZ (Inria), Clément PAPON (XLIM)
Revision	1.0
Mots clé	Cybersécurité, sécurité des réseaux
Keywords	Cybersecurity, network security

– Piloté par

– Financé par

– Opéré par

Contents

Introduction **2**
Context . . . 2
Impact on 5G and future networks . . . 5

1 LAKE and the EDHOC protocol **7**
1.1 The EDHOC Protocol . . . 7
1.1.1 A Primer on SIGMA . . . 7
1.1.2 EDHOC Additions to SIGMA . . . 8
1.1.3 EDHOC Protocol Outline . . . 9
1.1.4 Key Schedule . . . 11
1.2 Security Goals . . . 13
1.3 Security Analysis of EDHOC . . . 14
1.4 Discussion . . . 19

2 Lawful Interception in Mobile Networks **20**
2.1 The LI-vs-privacy conundrum . . . 20
2.2 Traditional approaches to Lawful Interception . . . 23
2.2.1 Key Escrow . . . 23
2.2.2 The Proof-of-Work Approach . . . 23
2.2.3 Unlawful interception: mass surveillance . . . 24
2.3 The LIKE approach . . . 24
2.4 Towards privacy-preserving LI in future mobile networks . . . 30

Conclusion **31**

Bibliography **36**

Introduction

Note from the project: This document gathers contributions from two NF-HiSec workpackages, WP3 and WP4. Initially foreseen as an individual work from WP3, it includes contributions from WP4 to include the collaboration between XLIM and Inria AIO.

Scope and Contributors. This deliverable compiles the state-of-the-art on secure channel establishment in constrained environments and its lawful interception. The work was carried out in collaboration between XLIM and the Inria AIO team, in the context of Work Packages 3 and 4 of the NF-HiSec project. The deliverable is partly based on the following publication, produced thanks to the NF-HiSec project:

- Lopez Perez et al. "EDHOC Is a New Security Handshake Standard: An Overview of Security Analysis." Computer 57.9 (2024): 101-110.

Context

Authenticated key-exchange and secure channel-establishment. Establishing a secure communications channel between two or more peers who communicate over a public channel is one of the most fundamental goals in cryptography. At the very least, the secure channel should guarantee that the users situated at its endpoints can be sure of:

- Each other's identities (or, at the very least, of their partners' legitimacy with respect to some predicate) – Authentication;
- The confidentiality, authenticity, and integrity of the messages they exchange on that channel, with respect to all outsiders –Security;
- the fact that, even if the user itself or one of its communication partners gets corrupted, their past communication sessions are secure – Perfect Forward Secrecy (PFS).

In order to communicate securely, the two protocol participants first use their long-term credentials, as well as possibly some ephemeral values, to run an *Authenticated Key-Exchange (AKE)* protocol. At the end of this protocol, Alice and Bob will have authenticated each other, and will have moreover computed a tuple of *session keys*. These keys are then used to encrypt

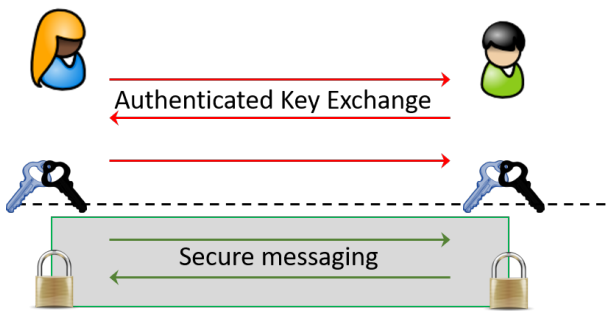

Figure 1: The generic structure of a secure-channel establishment protocol.

and authenticate all subsequent communications in a second, *secure-messaging* phase of the secure-channel establishment. This is also depicted in Figure 1.

The goal of a secure-channel establishment protocol is to authenticate the two parties participating in the exchange[1] and to derive a shared key which can be used for encrypting and authenticating the messages between them.

There are many secure channel establishment protocols used in the wild today. This includes standardized protocols such as TLS 1.3, IKEv2, SSH – or, in mobile networks, the AKA protocol[2]. The problem of secure-channel establishment is well-studied in the literature for traditional networks – but it can be tricky to address in non-standard use-cases.

The rise of the Internet of Things (IoT) has driven organizations like the Internet Engineering Task Force (IETF) to develop protocols that meet the requirements of the involved devices and networks. Some of the challenges are their low processing power, scarce bandwidth, battery lifetimes and reduced data rates. To address these issues, the Internet community has developed and standardized protocols that are tailored for constrained environments. The results of these efforts include the Constrained Application Protocol (CoAP) and the Object Security for Constrained RESTful Environments (OSCORE). CoAP is a specialized web transfer protocol that provides the REST services of HTTP but with reduced overhead and processing. OSCORE is a security protocol that can be applied to protect CoAP communication, including end-to-end encryption and integrity across CoAP proxies, replay protection and binding of responses to requests.

OSCORE itself does not define a key establishment protocol. Prior to using OSCORE, the communicating parties must establish a security association, including a shared cryptographic key through some out-of-band mechanism. To resolve this matter, the IETF created the Lightweight Authenticated Key Exchange (LAKE) working group which developed and standarized the Ephemeral Diffie-Hellman Over COSE (EDHOC) protocol. EDHOC is designed to

[1]Depending on the considered use-case, sometimes unilateral authentication (server-side-only) is sufficient. This is the predominant way in which TLS is used when deployed in https.

[2]The focus of this deliverable is on synchronous communication. In the last decade, asynchronous secure-channel establishment has also been introduced, and several standards, including MLS, are under way for guaranteeing this functionality.

enable an authenticated Diffie-Hellman key exchange and shared secret key derivation between two peers, both possibly operating on resource-constrained devices utilizing low-power IoT radio communication technologies. EDHOC, like OSCORE, builds on the Concise Binary Object Representation (CBOR) encoding and the object security format CBOR Object Signing and Encryption (COSE), enabling reduced message sizes and combined code footprint.

EDHOC and OSCORE provide an application layer alternative or complement to Transport Layer Security (TLS) for protection of CoAP. TLS 1.3 is the go-to standard for web security but faces challenges in constrained environments due to large handshake message sizes and more elaborate state machines. The same applies to Datagram TLS (DTLS) 1.3 used for connectionless transports, such as User Datagram Protocol (UDP). A DTLS handshake transfers around 1 kB of data [35].

EDHOC, for comparison, allows for handshakes that transfer 100+ bytes of data, requires only three mandatory flights, is transport agnostic, and code size can be kept low by reusing the same elements as OSCORE. Fedrecheski *et al.* [24] show that EDHOC achieves a 7.75× reduction in message footprint, 1.9× reduction in energy and time, and uses up to 4× less flash and RAM than DTLS 1.3.

Lawful Interception. One of the requirements in mobile-network secure-channel establishment is that of *lawful interception* (LI). This is a sensitive topic in mobile communications, and it refers to authorities in a specific country being able to exceptionally be granted access to specific information pertaining to specific conversations, which are otherwise meant to be private.

LI requirements in mobile communications are featured in 3GPP technical documents [3] and are standardized by organizations such as ETSI. LI is the procedure through which a law enforcement agency, holding a legal warrant, can obtain information about phone calls: either metadata (time of calls, identity of the callers) or contents of conversations happening in real time. By law, a mobile network operator *must* provide the data requested and specified by a warrant. Three main types of requirements regulate LI: user-privacy requirements, LI-security requirements, and requirements on encryption.

R1 **User Privacy:** the interception is limited in time (as dictated by the warrant) and to a targeted user. The law enforcement agency should not get data packages or conversations outside the warrant, from the same or other users.

R2 **LI Security:** LI must be undetectable by either users (whose quality of service should stay the same) or non-authorized third parties (including other law-enforcement agencies). The intercepted data must be provided promptly, with no undue delay.

R3 **Special case:** if it implements encryption, the operator must provide either the decrypted content, or a means to decrypt that content (*e.g.,* a decryption key). However, if the users

employ other means of encryption, not provided by the operator, the latter is under no obligation to provide decrypted (or decryptable) conversations.

Many mobile network operators offer the End-to-End security of voice- and text- data transiting through their networks. This E2E security does protect mobile users from exposing potentially highly-sensitive data to eavesdroppers. Unfortunately, due to LI requirements, every piece of data that transits on mobile networks is visible to the operator which owns the infrastructure. In this way, the operator can be sure the correctly respond to any LI warrants addressed to it.

Yet, privacy is a human right. The Universal Declaration for Human Rights [45], states: "*No one shall be subjected to arbitrary interference with his privacy [...] or correspondence [...]. Everyone has the right to the protection of the law against such [...] attacks.*" The United Nations describes privacy as a cornerstone of other basic human rights, like "*the free development and expression of an individual's personality, identity, and beliefs, and their ability to participate in political, economic, social and cultural life*" [46].

Edward Snowden's 2013 revelations of widespread mass surveillance engendered public outcry. Advocates for sacrificing privacy for the sake of (inter-)national security clashed with privacy supporters warning of censorship and autocracy. Examples of illegal mass-surveillance abound today. The NSA once collected call data from all Verizon customers, and data pertaining to calls in the Bahamas and Afghanistan [26]. During the COVID-19 pandemic, contact-tracing data was used in order to facilitate criminal investigations [22]. A recently-proposed EU regulation on moderating child sexual abuse material (CSAM) in encrypted communications enables mass client-side scanning, in spite of outspread criticism from both scientists [42] and socio-economical entities [14].

Mass-surveillance is a threat to basic human rights. Yet, even strong privacy advocates agree that investigations *limited in scope and motivation* (by lawfully-obtained warrants) can be legitimate [5]. This is the type of limited Lawful Interception (LI) that the *EU resolution on security through encryption and security despite encryption* supports [17].

Impact on 5G and future networks

Lawful Interception (LI) has been a legal and technical requirement for over 30 years in mobile communications, featured prominently in 3GPP specifications [2, 1, 4]. Every operator that provides end-to-end encrypted user communication is subject to such requirements. Yet, current approaches to Lawful Interception in mobile networks seriously undermine user privacy, by obliging mobile network operators to be aware of all the (potentially sensitive) data and metadata transiting through their networks.

While even privacy advocates understand the need for fine-grained, targeted lawful-interception, the loss of privacy to mobile users that stems from current LI-response practices is enormous.

The NF-HiSec project proposes to provide technical means of performing LI, while simultaneously improving the privacy of mobile users worldwide. We will in particular also focus on LI aspects of protocols that are currently being standardized, such as EDHOC, in an effort to contribute, in a real way, to a change of perspective and mentality on the apparent opposition of security and privacy.

Chapter 1

LAKE and the EDHOC protocol

1.1 The EDHOC Protocol

1.1.1 A Primer on SIGMA

EDHOC is designed following the SIGMA protocol, a family of key-exchange protocols that introduce a general approach to building authenticated Diffie-Hellman (DH) protocols using a combination of digital signatures and message authentication code (MAC) functions. SIGMA is widely used and constitutes the cryptographic basis of known protocols such as the Internet Key Exchange (IKE) (IKE version 1 and version 2) or Transport Layer Security (TLS) version 1.3. In SIGMA, each party can authenticate to the other without needing to know the peer's identity beforehand. This property allows the protocol to support identity protection, a requirement that plays a central role in its design. More specifically, it decouples the authentication of the ephemeral Diffie-Hellman public key (G^X, G^Y) performed via digital signatures, from the binding of key and identities, done by computing a MAC function. The most basic form of the SIGMA protocol, without identity protection, consists in sending both the digital signatures and the MAC (see Fig. 1.1). The output of the protocol is a session key derived from the Diffie-Hellman shared secret (G^{XY}).

In case the identity protection functionality is needed, one of the peers can delay communicating its own identity until it learns the peer's identity in an authenticated form. This gives rise to two variants of SIGMA: *(1)* SIGMA-I, which protects the identity of the peer initiating the session, called Initiator, and *(2)* SIGMA-R, which protects the identity of the peer engaging in an already initiated session, called Responder.

To reduce the size of the messages on the wire, of special interest in constrained environments, SIGMA introduces the MAC-then-Sign variant. In MAC-then-Sign, MAC is included under the Signature, allowing to reduce message length by not sending the MAC explicitly. The MAC-then-Sign messages are therefore shorter for the length of the MAC. As long as the MAC covers the identity of the signer the same security of the basic SIGMA protocol is preserved. Fig. 1.1

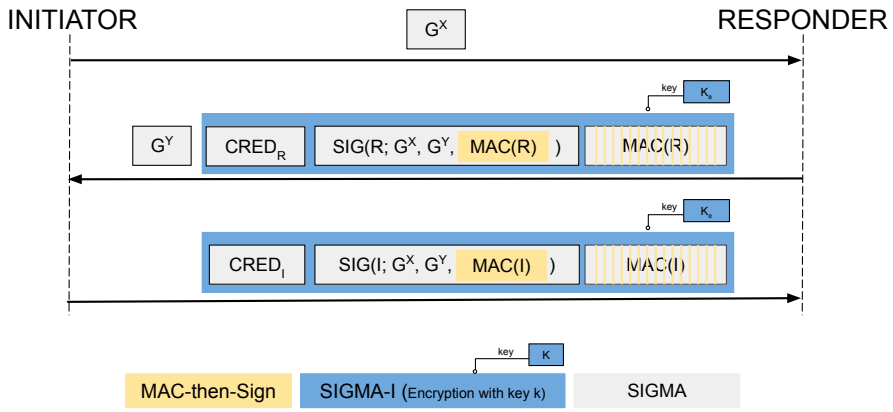

Figure 1.1: Message flow of the SIGMA protocol. The blue boxes denote additions to the SIGMA-I variant. The yellow boxes denote additions to the MAC-then-Sign variant.

ID	Initiator	Responder
0	Signature	Signature
1	Signature	Static Diffie-Hellman
2	Static Diffie-Hellman	Signature
3	Static Diffie-Hellman	Static Diffie-Hellman

Table 1.1: Current authentication methods registered by IANA.

shows the differences between the basic SIGMA protocol, SIGMA-I and MAC-then-Sign variants.

1.1.2 EDHOC Additions to SIGMA

EDHOC cryptographic core follows the MAC-then-Sign variant of the SIGMA-I protocol. However, apart from conventional signature keys used for authentication, EDHOC enables the use of static Diffie-Hellman keys. The EDHOC "authentication method", sent in the first message, defines which type of the authentication key the peers are using (see Table 1.1).

The use of static Diffie-Hellman keys allows significant reduction in message size. While following the SIGMA-I MAC-then-Sign structure, EDHOC replaces the digital signature with a MAC in case the peer is using the Static Diffie-Hellman key for its authentication. This works because the peer can combine the static Diffie-Hellman key pair with an ephemeral key pair of the other peer and produce an ephemeral-static shared secret to compute the MAC. The peer then needs to send a shorter MAC (e.g. 8 bytes) instead of a digital signature (e.g. 64 bytes).

To enable crypto agility, flexibility and modularity in the design, EDHOC includes a list of ordered algorithms in its first message. A single integer encodes the cipher suite: a set of algorithms such as the authenticated encryption algorithm, a hash function, an elliptic curve

ID	AEAD	Hash	MAC length	ECDH Curve	Signature	Application AEAD
0	AES-CCM-16-64-128	SHA-256	8	X25519	EdDSA	AES-CCM-16-64-128
1	AES-CCM-16-128-128	SHA-256	16	X25519	EdDSA	AES-CCM-16-64-128
2	AES-CCM-16-64-128	SHA-256	8	P-256	ES256	AES-CCM-16-64-128
3	AES-CCM-16-128-128	SHA-256	16	P-256	ES256	AES-CCM-16-64-128
4	ChaCha20/Poly1305	SHA-256	16	X25519	EdDSA	ChaCha20/Poly1305
5	ChaCha20/Poly1305	SHA-256	16	P-256	ES256	ChaCha20/Poly1305
6	A128GCM	SHA-256	16	X25519	ES256	A128GCM
24	A256GCM	SHA-384	16	P-384	ES384	A256GCM
25	ChaCha20/Poly1305	SHAKE256	16	X448	EdDSA	ChaCha20/Poly1305
-24, -23, -22, -21	Private use					

Table 1.2: Current cipher suites and their identification integer as registered by IANA.

(see Table 1.2).

1.1.3 EDHOC Protocol Outline

The protocol consists of three mandatory messages, an optional fourth message, and an error message. Figure 1.2 shows the message flow for the EDHOC protocol outlined below.

- **Message 1.** The Initiator sends the first message containing the setup information, which includes the authentication method to be used, the cipher suites, the ephemeral Diffie-Hellman public key G^X, a connection identifier C_I (with no cryptographic purpose) and the additional information called external authorization data EAD_1.

- **Message 2.** If the Responder agrees on the method and cipher suites, it generates an ephemeral key pair (Y, G^Y) and computes the Diffie-Hellman shared secret G^{XY}. If the Responder uses static DH for authentication with key pair (R, G^R) then it also computes the ephemeral-static Diffie-Hellman shared secret G^{RX}. The Responder derives two intermediate pseudo-random keys using the Key Derivation Function `EDHOC_KDF`: PRK_{2e} and PRK_{3e2m}, see Fig. 1.3. The index in the key name indicates in what message and operation the key is involved. Thus, PRK_{2e} is used for the encryption of the message 2 whereas PRK_{3e2m} is used for encryption of message 3 and MAC of message 2. The Responder also computes a transcript hash TH_2 that includes the first message and the ephemeral Diffie-Hellman public key G^Y. When the Responder uses a Static Diffie-Hellman key, authentication is ensured by a MAC_2 (methods 1 and 3). This MAC is derived using `EDHOC_KDF` with PRK_{3e2m} and some additional information ($context_2$) that includes the previously calculated transcript hash TH_2 and its own credentials $CRED_R$. Otherwise

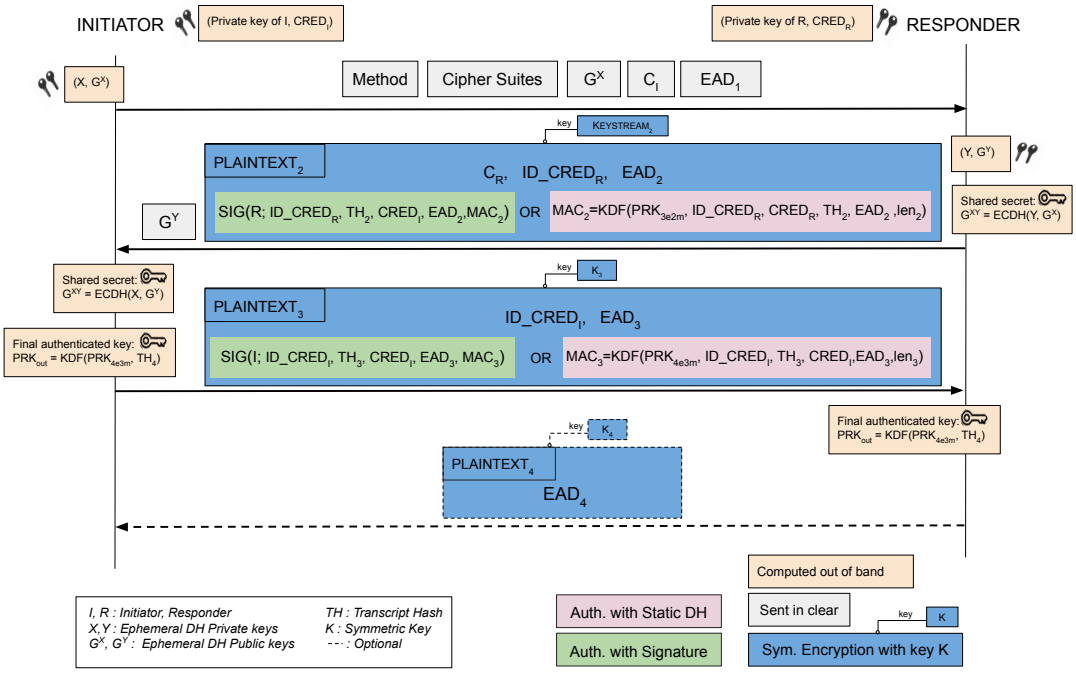

Figure 1.2: The EDHOC message flow. The fields (X, G^X) (resp. (Y, G^Y)) represent ephemeral private and public key of the Initiator (resp. Responder). Field $CRED_I$ (resp. $CRED_R$) denotes the authentication credentials containing the public authentication keys of I (resp. R). Method is an integer (0-1-2-3) denoting the authentication method (see Table 1.1). Cipher Suites is an ordered set of preferred algorithms (see Table 1.2). If method is either 0 or 1 for the Initiator (resp. 0 or 2 for the Responder), then Sig or MAC equals Sig. The fourth message is optional (represented with a dashed line).

(methods 0 and 2), the Responder authenticates via a signature. The parameters used in the signature algorithm are: *(1)* ID_CRED_R, an identifier to facilitate retrieval of $CRED_R$. *(2)* external authorization data, including TH_2, $CRED_R$ and EAD_2, and *(3)* the previously calculated MAC_2. Message 2 is finally encrypted using keystream K_2, derived from PRK_{2e}.

- **Message 3.** After receiving the second message, the Initiator computes the shared secret G^{XY}, the decryption key K_2 derived from PRK_{2e}, and the pseudo-random keys PRK_{3e2m}, all used for verifying message 2. If the Initiator uses static DH for authentication with key pair (I, G^I) then it also computes the ephemeral-static Diffie-Hellman shared secret G^{IY} used in the derivation of PRK_{4e3m}, see Fig. 1.3.

  I verifies R's credentials by means of either the signature or MAC. I then computes a new transcript hash TH_3 including R's credentials, and a MAC, MAC_3, using `EDHOC_KDF` on PRK_{4e3m} and some additional data ($context_3$) that includes the previous hash TH_3 and its own credentials $CRED_I$. Depending on the method used, the MAC is either sent raw or protected by a signature. It is further encrypted using keying material K_3 / IV_3 derived from PRK_{3e2m}.

- **Message 4.** The Responder receives the third message and decrypts it to authenticate the Initiator. R can then send an optional fourth message containing external authorized data EAD_4 as acknowledgment, encrypted using the keying material K_4 / IV_4 derived from PRK_{4e3m}.

1.1.4 Key Schedule

EDHOC uses a similar key schedule to the Noise XX pattern [41], a handshake pattern within the Noise protocol framework designed for establishing secure communication channels between two parties with static long-term keys.

Two functions are involved in the key schedule: *(1)* `EDHOC_Extract` and *(2)* `EDHOC_Expand`. In a first stage, `EDHOC_Extract` receives as input a salt and an Input Keying Material (IKM), and generates a fixed-length pseudorandom key (PRK) that is uniformly random-distributed. In a second stage, `EDHOC_Expand` takes the previously generated PRK, a sequence named info, and the key length, and outputs several additional pseudorandom keys that will be used both in the `EDHOC_KDF` and as output keying material. The definition of both functions depends on the hash algorithm of the cipher suites. Details on the different keys used in EDHOC are illustrated in Fig. 1.3.

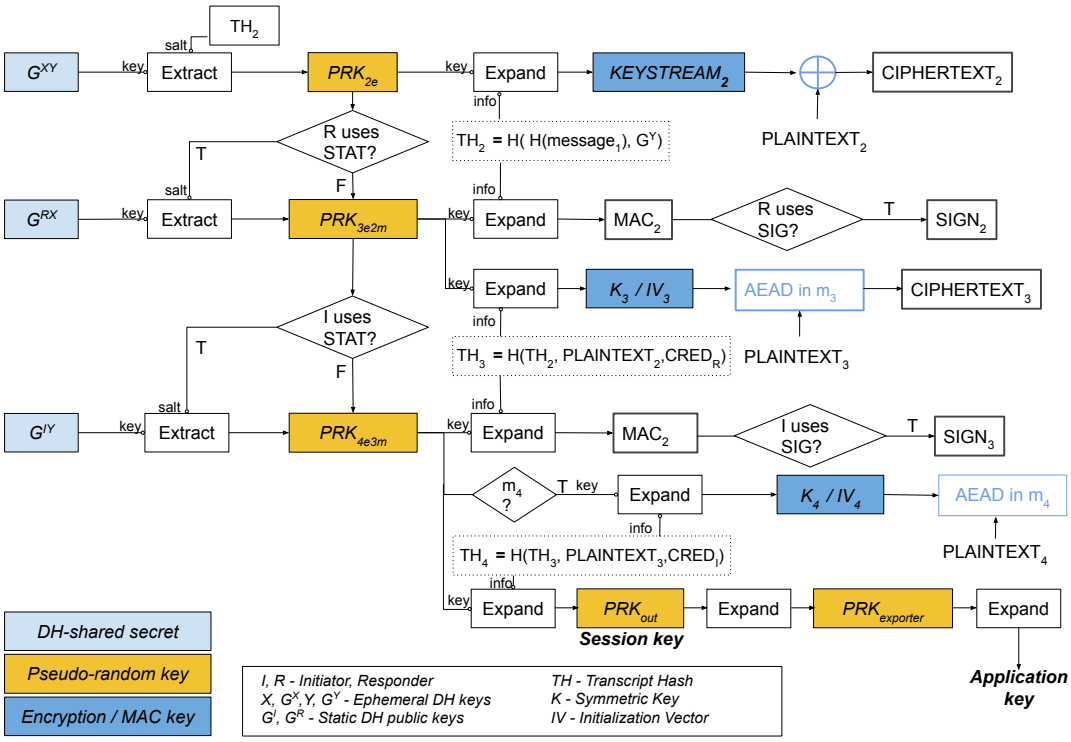

Figure 1.3: The EDHOC key schedule as standardized in RFC 9528, adapted from Vučinić *et al.* [48].

1.2 Security Goals

The security goals of the protocol adhere to the requirements established by Vučinić *et al.* [47]. They can be summarized as follows:

- **Confidentiality.** The shared secret established at the end of the session must be known only to the two authenticated peers. In addition, an active attacker who has compromised either one of the peer's private keys shall still not be able to compute past session keys (Forward Secrecy). This is achieved by generating session keys from ephemeral keys, which are freshly defined in each session. Therefore, even if a session key is compromised, only the data from the current session is at risk, but not past communications.

- **Mutual authentication.** At the end of the session, each peer should have freshly authenticated the other peer. Both peers must agree on a fresh session identifier, roles and credentials. Compromising the long-term secret of one party should not break that party's authentication of their peer in the given session (Key Compromise Impersonation resistance). In addition, the protocol shall offer protection against identity misbinding attacks, where a peer becomes unknowingly associated with a third party.

- **Identity protection.** "Identity" refers to a unique identifier that allows different entities within the protocol to recognize and authenticate each other. Identity may be represented by a cryptographic certificate, public keys, MAC addresses or any other unique identifier exchanged during the protocol execution. The protocol must protect the identity of one of the peers against active attackers and the identity of the other peer against passive attackers.

- **Cryptographic strength.** The target security level of the protocol's key shall be greater or equal than 128 bits, meaning that the complexity of an attack is greater or equal to 2^{128} to brute-force the key. This security level targets the strength of the authentication, established keys, and protection of negotiation for all cryptographic parameters.

- **Protection of external security data.** For efficiency, the protocol should support integration of external security applications using so called "External Authorization Data" (EAD) message fields having the same level of protection as the protocol message they are carried within.

- **Downgrade protection.** In response to long deployment lifetimes, the protocol must support cryptographic agility, including modularity and negotiation of preferred cryptographic primitives. At the end of the session, both peers must agree on the cryptographic algorithms that were proposed and chosen. Downgrade protection is crucial to prevent attackers from forcing the use of weaker security features. Some related attacks include *(1)* cipher suite downgrade attack, in which attackers attempt to manipulate the negotiation

process to force the use of less secure cipher suites, or *(2)* key material downgrade attack, in which an adversary intercepts the key derivation process and modifies the generated key to use weaker or compromised key material.

1.3 Security Analysis of EDHOC

Before TLS 1.3, the process of standardization and formalization often occurred sequentially. Formalization, which involves the rigorous mathematical analysis of the protocol's security properties, typically occurred independently or as part of academic research efforts. Meanwhile, standardization efforts, led by organizations such as the IETF, focused on developing and documenting the protocol specification, considering practical deployment considerations, interoperability requirements, and feedback from implementers. However, with the increasing recognition of the importance of formal analysis in protocol design, especially in the context of Internet security and privacy, there has been a growing emphasis on integrating formal methods into the standardization process from an early stage. In this regard, the standardization of EDHOC followed this parallel approach, with formal analysis informing the design and development of the protocol specification from the outset.

In order to obtain proofs that security protocols are correct, one first needs to model them mathematically. Two models of protocols have been considered to study the security requirements of EDHOC: *(1)* a symbolic model, and *(2)* a computational model. The symbolic model, often called Dolev-Yao model, is an adversary model that employs idealized cryptographic primitives and that allows the adversary to control the communication channel and interact with protocol sessions by dropping, injecting or modifying messages. In this model, the cryptographic primitives are represented by function symbols considered as black-boxes, the messages are terms on these primitives, and the adversary is restricted to compute only using these primitives. As for the computational model, the messages are bit strings, the cryptographic primitives are functions from bit strings to bit strings, and the adversary is any probabilistic Turing machine. In this model, a security property is considered to hold when the probability that it does not hold is negligible in the security parameter. In the computational model it is common to use a code-based game framework where initially the problem is represented as a code-based game, named game 0, and it is sequentially modified creating a chain of games in which the last game has the property that it cannot be won by the adversary, i.e. the advantage is zero. By using the fundamental lemma of game playing (see Bellare *et al.* [10] for details), the probability of the adversary winning the original game can be bounded. Even though the computational model is much more realistic, the symbolic model is suitable for automation, essentially by computing the set of all messages the adversary can know.

In this section, we discuss the main vulnerabilities that were found by the community in the security analyses of EDHOC and how they were resolved in order to meet the listed security

Security goal	Vulnerability	Mitigation	Initial draft	Improved draft	Method	Proof type	Ref.
Confidentiality	Weak final key. Reuse of the last key-exchange internal key	Final key depending on PRK_{4x3m} and TH_4 (PRK_{out})	12	14	0-1-2-3	S	[28]
	Transcript collision attack	Reorder arguments in the hash function	12	14	0-1-2-3	S	[28]
	Duplicate Signature Key Selection (identity misbinding attack)	Include full/unique authentication credentials in the hash function. Build transcript hashes based on plaintext	14	17	0	C	[27]
	Key reuse	Not to reuse keys across calls of $EDHOC_Extract$ and $EDCHO_Expand$	14	17	0	C	[27]
	Salt Collision Attack	Use TH_2 as salt in the HKDF Extract function to derive PRK_{2e}	15	16	3	C	[16]
Mutual authentication	KCI	Modify the construction of message 3	15	-	3	C	[16]
	Leaking ephemeral secrets breaks authentication	Entity authentication should only rely on long-term authentication secrets	12	14	0-1-2-3	S	[28]
	Injective agreement	Add a fourth message as an option	00	Op.	0-1-2-3	S	[40]
Identity protection	Initiator impersonation	Include the Initiator identity in the list of trusted identities for the Initiator	12	14	0-1-2-3	S	[28]
	Partial privacy disclosure of the Responder's identity	Authenticate the first message and provide a way to validate the second message	07	-	0-1-2-3	S	[31]
Cryptographic strength	Attacks in 2^{64} operations for the Responder	Add a fourth message	15	Op.	3	C	[16]
Protection of external data	AEAD Key/IV reuse	Do not allow message recomputation from stored data	12	14	0-1-2-3	S	[28]
Non-repudiation	Unclear intended use	The Initiator should verify whether the identity of the Responder matches the intended one.	00	05	0-1-2-3	S	[40]
	Malleable signatures	Do not accept low-order points or the identity group element	12	-	0-1-2-3	S	[28]
	Sessions sharing the same PRK_4e3m	Do not accept low-order points or the identity group element	12	-	0-1-2-3	S	[28]

Table 1.3: Different vulnerabilities found during the security analysis of EDHOC and their corresponding mitigations. Op. denotes optional, and - denotes not included. S denotes symbolic analysis and C denotes computational analysis.

goals. A summary of the vulnerabilities and their proposed mitigations can be found in Table 1.3.

- **Confidentiality.** Jacomme *et al.* [28] performed a symbolic analysis of draft 12 on all authentication methods and found a flaw in the key derivation that lead to a weak session key, due to a reuse of the last key exchange internal key (PRK_{4e3m}). Their proposed fix was to add a final key derivation that would depend on both PRK_{4e3m} and TH_4. The advantages of this improvement are: *(1)* the session key is different from the MAC key, *(2)* a key confirmation implies authentication of all the data, *(3)* a dishonest party cannot control the final value of the session key and *(4)* the final state of the protocol is simplified since only the session key needs to be stored, rather than storing a key and a transcript. The improvement was added in draft 14 and formally verified (in a computational model) by Günther *et al.* [27].

  Later on, Günther *et al.* [27] performed a computational proof of draft 14 using authentication method 0 and suggested including full/unique credentials in the transcript hashes (TH_3 and TH_4). The aim was to strengthen EDHOC against attacks leveraging non unique credentials, such as identity misbinding attacks, where a legitimate but compromised peer manipulates the honest peer so that it becomes unknowingly associated with a third party.

  Lastly, Cottier and Pointcheval [16] performed a computational proof of draft 15 using method 3 and detected a salt collision attack (an attacker manages to find two different inputs that, when combined with their respective salts, produce the same hash value). Indeed, previous to their suggestion, an empty string was used in the derivation of PRK_{2e}. However, this means that no additional randomness is added to the hashing process. Thus, they suggested replacing the empty string used as salt with TH_2 in the derivation of PRK_{2e}. This proposal was included in draft 16.

- **Mutual authentication.** Norrman *et al.* [40] performed a formal analysis of all four authentication methods in draft 00 in a symbolic model. In their analysis, they proved two flavors of mutual authentication. The first one is injective agreement, which guarantees to an initiator I that whenever I completes a run with a Responder R, then R has been engaged in the protocol as a Responder. It also guarantees that I and R agree on a set of parameters, including the session key material. The corresponding property for R is analogous. The second variant of authentication is implicit agreement, which establishes that if the Initiator I (resp. Responder R) assumes that the Responder R (resp. Initiator T) knows the session key material, then it must be the intended party. In their analysis they show that implicit agreement on the session key material and the initiator's identity hold for all four authentication methods. Contrary, given that EDHOC aims to protect the Initiator's identity, injective agreement on the initiator's identity does not hold for

any of the methods. As for the injective agreement on the session key material, it is not supported whenever the Initiator uses methods 1 or 3, i.e., static Diffie-Hellman key. To solve it, they propose to add a fourth message from R to I carrying a MAC based on a key derived from the session key material. The optional message four was added by the LAKE Working Group as an optional feature of the protocol.

Cottier and Pointcheval [16] completed a computational proof of draft 15 using authentication method 3, i.e., static Diffie-Hellman keys. They discovered a Key Compromise Impersonation (KCI) attack on K_3, where an attacker gains access to a peer's private key and compromises and impersonates this peer. It turns out that K_3, used by the Initiator to encrypt message 3, is computed by calling `EDHOC_Expand` on PRK_{3e2m}, and can be computed by an adversary that knows the Initiator ephemeral key G^X. In order to break the Initiator's authentication, an adversary must know as well MAC_3. However, in the most constrained cipher suites (identifiers 0 and 2 in Table 1.2), MAC_3 is 64 bits long. They suggest modifying the construction of message 3 by splitting it in two parts: *(1)* the first one contains the identity credentials of the initiator and is encrypted using the corresponding encryption key K_3 derived from PRK_{3e2m}, *(2)* the other half corresponds to the authentication tag MAC_3 and the EAD_3 and is sent without encryption. The main reason why this change was not included in the draft was that it did not offer protection against active attackers, since the identity credentials were not be protected with a MAC. The proposed alternative is to use a longer 16 bytes MAC_3, which was already contemplated by some cipher suites, such as 1 and 3 (see Table 1.2).

Ferreira [25] performed a computational analysis of the final draft of EDHOC, draft 23, on the four authentication methods. Similarly to Norrman *et al.* [40], they proved that a fourth message is necessary only when the initiator authenticates by means of a static DH key, i.e. authentication methods 1 and 3. For these authentication methods, the fourth message proves to the initiator that the responder shares the same key PRK_4. Furthermore, it also proves to the initiator that the responder shares the same session identifier.

- **Identity protection.** Kim *et al.* [31] studied draft 7 leveraging BAN Logic, a set of rules for defining and analyzing information exchange protocols, and AVISPA (Automated Validation of Internet Security Protocols and Applications), a tool designed for the automated analysis and validation of security protocols and applications. Their results show vulnerability against privacy attacks affecting the identity credentials (ID_CRED_R and ID_CRED_I). Thus, an attacker can easily break the privacy of ID_CRED_R by establishing the session key with the Responder, leading to a partial privacy disclosure of the Responder's identity. They recommend authenticating message 1 and providing a way to validate message 2.

  Jacomme *et al.* [28] detected a privacy leak in draft 12 when the list of trusted identities for

the Initiator I is only missing I's identity. They proposed to fix it by adding the Initiator identity in its own list of trusted identities.

In their computational analysis of draft 23 of the protocol, Ferreira [25] suggests that identity privacy can be enhanced by systematically using padding before encryption, particularly with plaintext elements like EAD_2, EAD_3 and EAD_4. Padding can obscure the actual size of the data being transmitted, making it harder for an adversary to infer information about the identities involved. However, padding should be used with care as it enlarges the messages and increases bandwidth consumption.

- **Cryptographic strength.** The cryptographic strength of the protocol was formally studied by Cottier and Pointcheval [16]. They proved that in the three-flow scenario and using the most constrained cipher suites with 8-byte long MACs, the protocol provides a 64-bit security level for the Responder authentication. They further showed that a fourth message using authenticated encryption (AEAD) from the Responder to the Initiator increases this security up to a 128-bit level, being consistent with the security requirements.

  Ferreira [25] showed that the security of EDHOC depends essentially on that of the authenticated encryption algorithm used. They show that the cipher suite based on A256GCM is preferable for high security applications, in contrast with ChaCha20Poly1305, also recommended in the EDHOC draft for the same kind of applications.

- **Protection of external data.** Jacomme *et al.* [28] detected an attack in draft 12 due to the possibility of resending the last message, which lead to a nonce reuse of AEAD, breaking confidentiality and integrity. They therefore suggested not to allow message resending when using randomized signatures. This was specified in draft 14.

- **Non-repudiation.** Non-repudiation was highlighted by Norrman *et al.* [40] in their analysis of draft 00 and Jacomme *et al.* [28] in their study of draft 12. They signaled cases in which non-repudiation would be unclear. These include: *(1)* sessions sharing the same PRK_{4e3m} due to acceptance of low-order points or the identity group element and *(2)* signatures being malleable. These situations were considered side cases and were thus not included by the Working Group in the draft.

- **Downgrade protection.** There were no vulnerabilities found regarding downgrade attacks in any of the studies. The defined cipher suite negotiation in the specifications is thus found to be resistant against these attacks.

Table 1.4 summarizes how EDHOC meets the discussed security goals, including the corresponding authentication method for which the proof holds and the type of proof.

Security goal	**Method**			
	0	1	2	3
Confidentiality	S,C	S,C	S,C	S,C
Mutual authentication	S,C	S,C	S,C	S,C
Identity protection	S,C	S,C	S,C	S,C
Cryptographic strength	C	C	C	C
Protection of external data	S	S	S	S
Downgrade protection	S	S	S	S

Table 1.4: Summary of the EDHOC security analyses. *S* denotes symbolic proof and *C* computational proof. Method refers to the authentication method (listed in Table 1.1).

1.4 Discussion

The security analyses of EDHOC are restricted to the cryptographic core of the protocol, and thus, they do not capture all aspects of the protocol like negotiation of authentication methods and cipher suites.

Moreover, they do not consider other attack vectors in low-power devices that may undermine the security guarantee of EDHOC. Some examples include side-channel attacks (an adversary exploits information leak from the physical implementation of cryptographic operations, such as power consumption or electromagnetic emissions) or fault injection attacks (an adversary introduces faults or errors into a system's operation with the aim of compromising its security or integrity).

EDHOC has included a Post Quantum Cryptography (PQC) variant that employs a PQC Key Encapsulation Method (KEM). Even though EDHOC is currently only specified for use with key exchange algorithms of type ECDH curves, any KEM, including PQC KEMs, can be used in method 0. However, current PQC algorithms have limitations compared to Elliptic Curve Cryptography (ECC), and the data sizes would be problematic in many constrained IoT systems. The use of other key exchange algorithms to replace static Diffie-Hellman authentication (methods 1,2 and 3) will require the definition of new methods in the specification. Up to date, there are no security analyses of the Post Quantum variant. Even though Jacomme *et al.* [28] mentioned in their work that they studied it, no results were presented. Given the evolution of quantum computers, it would be interesting to perform further analyses in the future.

Lastly, the IETF LAKE Working Group plans to standardize a new pre-shared key (PSK)-based method, to be also employed for rekeying, which will require a formal analysis in the future.

Chapter 2

Lawful Interception in Mobile Networks

2.1 The LI-vs-privacy conundrum

In mobile networks, the communication between Alice and Bob passes through the serving networks of those two respective users. Although many serving networks provide secure channels over which Alice and Bob can exchange potentially highly-sensitive data, the intermediary operators are end points in that secure-channel establishment and hence have access to all the data and metadata the users exchange. This Meddler-in-the-Middle position allows the operator to respond to LI requests.

The LI environment. Although Lawful Interception legislation is different depending on the country enforcing it, its essence is somewhat similar. The concept of lawful interception entails that a number of authorities, acting in concentration, may perform an *exceptional*, *directed* breach of a user's privacy, which is *limited in time and scope*. The exact parameters limiting Lawful Interception are typically expressed in a legal document, such as a warrant or a subpoena. The warrant is usually signed by a legal authority and handed over, for use, to a law-enforcement agency. The warrant is served to the operator, which then must undo any decryption that it has put into place for the protection of user privacy, and hand over mobile data or metadata for the user or users designated by the warrant, and for its duration.

More abstractly, we note the existence of several *authorities*, that is, parties that can act together in consensus in order to provoke this exceptional and lawful access to private user data. Note also that the party responsible for allowing LI to be performed efficiently and successfully is the mobile network operator (MNO). Since LI requirements are enshrined in the legislations of most countries, no MNOs provide true, End-to-End secure communication between users, fearing they would not be able to provide user data/metadata when subpoenaed to do so.

We also note that, once the warrant is obtained, the access to user data may be more or less limited by the country's laws. For instance, it may be that ultimately, the collected data and metadata is only visible to the law-enforcement agency that was involved in collecting it.

Alternatively, several authorities might be privy to it.

THE ETHICS OF TECHNICALLY ALLOWING LAWFUL INTERCEPTION. Lawful Interception is a sensitive topic, because it infringes on a human right (albeit in a controlled way). If abused by the authorities in a systematic way, the backdoor we purposefully open in our protocol can lead to mass surveillance on entire nationfuls of people.

It is worth, therefore, expounding on the ethical aspects of doing research on Lawful Interception.

For almost a decade, mass surveillance has caused controversy, widespread protests, and scandals; and yet, it is on the rise, affecting users every day. The NSA, for instance, illegally collected phone-call data from all Verizon customers, and the data of all calls occurring in the Bahamas and Afghanistan [26]. During the present COVID-19 pandemic, Germany used contact-tracing data to pursue criminal investigations [22]. The need for privacy-enhancing solutions that provide transparency and limit mass surveillance has never been greater.

User privacy is a human right acknowledged, *e.g.,* by Article 12 of the Universal Declaration for Human Rights [45]: "*No one shall be subjected to arbitrary interference with his privacy* [...] *or correspondence* [...]. *Everyone has the right to the protection of the law against such* [...] *attacks.*" The European General Data Protection Regulation (GDPR) and e-Privacy both aim to protect privacy in digital environments, requiring minimal, transparent, secure, and user-controlled storage of data. Increasingly aware of mass surveillance, users now choose more frequently to secure their communications by using, *e.g.,* WhatsApp and Viber. In mobile networks, data is encrypted by mobile network operators, which have an incentive to improve the privacy they offer their users.

Unfortunately, mobile data remains at risk, especially when exceptional access to it lies with a single entity. In 2016, only the integrity of Tim Cook (Apple CEO) and his awareness of the danger of such a precedent prevented encrypted phone data to be given to the FBI [29]. His refusal was not a deterrent, and risks to privacy and encryption grow every day [21].

Law-enforcement agencies argue that mobile data can be pivotal to investigations, which are undermined by individuals "going dark" [15]. Even strong privacy advocates, such as Abelson *et al.* [5] agree that *targeted* investigations, *limited in scope and motivation*, can be legitimate and useful (see the corruption-scandal regarding Nicolas Sarkozy's campaign funds). It is this type of limited Lawful Interception (LI) that emerging EU legislation advocates [20].

Recent research [50] (see Section 2.2.2) has tried to find a middle ground between privacy and lawful interception, enabling the latter at high cost. Unfortunately, that approach sacrifices a crucial real-world requirement: timely (exceptional) decryption [3], and replaces legitimate authorities by more generic entities able to provide a proof-of-work.

As a result, the overwhelming impression is that there is a "[...] *need to choose between compliance and strong encryption*" (in the words of Joel Wallenstrom).

Yet, a promising approach exists which might lead to privacy-preserving LI. This approach,

called LIKE (see Section 2.3, combats mass surveillance in multiple ways. It *fine-grains* the window of interception to a single session, such that one exceptional opening will not affect past or future conversations. Moreover, the freshness used in the protocol is user- not authority-generated, thus *removing the need* for a centralized, secure party storing all the keys. We also divide the responsibility of exceptional opening between multiple authorities that *must agree* to lawfully intercept communications. Finally, we make the primitive *versatile*, allowing only one, or only several authorities to ultimately retrieve the session key. This makes our solution more privacy-preserving than mobile protocols today, while at the same time remaining compatible with the strictest LI-supporting 3GPP texts [3]. Although this approach is still very basic, and not properly tailored to use in modern network protocols, it reconciles the need for interception and that of privacy, without falling into the trap of mass surveillance.

More importantly: regardless of one's stand on it, Lawful Interception is part of our world, regulated by laws and standards. Disregarding it can lead to privacy threats (subversion or mass surveillance). Solutions that provide privacy but no LI are discarded as unlawful, regardless of their merits. We take the alternative approach: we analyze LI requirements and technically provide for them, while still maximizing data privacy.

Alternative LI approaches in mobile networks: technical challenges. The idea of introducing the operator as an endpoint to the otherwise E2E secure channel established in mobile communications is an accepted, de-facto practice for responding to LI requirements today. Providing alternatives to this approach is challenging for several reasons, including:

- **Efficiency.** Lawful Interception is often triggered in important law-enforcement and judicial matters; hence, the guarantee of receiving intercepted information promptly and integrally is crucial to the legal and justice systems.

- **Operator compliance.** The ultimate entity responsible for providing LI data is currently the mobile-network operator (MNO). The latter is forbidden from proposing, to its clients, encryption protocols that would render LI impossible or inefficient. In other words, alternative means of LI would need to come with a possibility for the MNO to prove that its approach is in fact LI-compliant according to the law.

- **Non-frameability.** Lawful Interception results might result in users being convicted for several crimes. As a result, it is crucial for alternative means of lawful-interception to ensure that users cannot be framed (by the operator or authorities) of having taken part in conversation it did not participate in.

2.2 Traditional approaches to Lawful Interception

2.2.1 Key Escrow

The concept of exceptional opening brings Lawful Interception close to the much more generic topic of key-escrow, which encompasses an enormous body of literature.

One of the earliest form of key-escrow, bordering on mass surveillance, was the introduction of the Clipper chip [38]. While purporting to be an encryption device for voice and data messages, it contained a backdoor allowing for unlawful mass interception of private data.

Once lawful interception was defined as a desirable goal (when performed in a restricted and regulated fashion), infrastructures [18] and technical means of interception were proposed for Voice-over-IP (VoIP) [7], in environments featuring multi-domain communication [12, 34], or more generally for all encrypted communications [36]. Subsequent solutions required an Identity-Based infrastructure [33, 44, 39, 13], the online availability of LI authorities [49, 23], or provided dynamic updates in key-escrow environments [32, 36].

Lawful Interception: within, yet beyond key-escrow. It should be noted that key escrow covers a very large range of applications. In many of these, key-escrow is not feasible on paper, as typical communications make it impossible to funnel all user communication through a single intermediate entity or path. In mobile environments, lawful interception bypasses this impossibility, as all mobile user communications are restricted in practice to the serving network of their mobile operator.

Another great disadvantage of past approaches to key-escrow is the assumption that authorities would be able to be online at all times, listening in and storing all the information passing through the public, escrowed channel. This is not only unrealistic today, but also amounts to mass surveillance.

Moreover, note that the requirements of operator-compliance and non-frameability render lawful-interception much more difficult to achieve than key-escrow in general.

2.2.2 The Proof-of-Work Approach

An alternative to key-escrow, which erred in favour of user-privacy, and it relied on partial key-escrow [43, 8]. The idea was to provide the authorities with part of the secret key, but then require them to invest resources in finding the other part. This idea was later extended to requiring authorities to provide (essentially) a proof of work in order to gain access to LI data [9, 50]. Another requirement of this approach was a win-one-win-all approach, which makes the retrieval of an initial key hard, but subsequent keys easy.

Unfortunately, that type of key-escrow contravenes LI requirements on mobile networks since the response to warrants cannot be returned in a timely fashion. Moreover note that a proof of work is merely a proof of investment and financial ability – and does not, in any way, reflect

the lawful nature of the approach. Organized crime syndicates can provide proofs-of-work as quickly as, or quicker than, legitimate authorities. Finally, the win-one-win-all approach renders this approach dangerously close to turning, from LI, to mass-surveillance.

2.2.3 Unlawful interception: mass surveillance

The Lawful Interception setup also resembles that of reverse firewalls [37] – which builds on related work pioneered by Young and Yung [51, 19, 30]. Although apparently similar, the setup of these works is complementary to ours. Kleptography describes ways for users to abuse protocols such that the latter appear to be running normally, while information (including keys) is allowed to leak. For instance in key-exchange, a government agency could substitute the implementation of the protocol by one with a backdoor, to make the key recoverable even without formal LI. Although malicious users Alice and Bob might attempt to misbehave and avoid Lawful Interception, it is a requirement of LI that operators prove compliance with LI requirements.

2.3 The LIKE approach

This state of affairs motivated work on Lawful-Interception Key-Exchange [6, 11], which defined a novel cryptographic primitive called Lawful-Interception Key Exchange (LIKE, in short). This protocol runs in the context of mobile communications, between two end users, Alice and Bob. The communication is mediated by two operators, affiliated with the serving networks serving Alice and Bob. The setup supposed the existence of a variable number n of authorities (*e.g.,* a court of justice, a law enforcement agency, operators), which all parties must agree on.

In LIKE, the end users establish a secure channel by computing some session keys – to be used for encryption and authentication. The operators that forward communication between the end users do not compute the session keys; instead, they output a public *session state*. At this point, unless lawful interception occurs, Alice and Bob's communication is end-to-end secure.

If an LI demand is made by the set of n authorities, the latter use the public session state to extract, each, a trapdoor for that session. The use of all n trapdoors will then yield the session key. Importantly, unless they are an authority, operators *cannot* recover the end users' key; instead they forward and verify the compliance of exchanged messages (else, the operator halts communication, believing the end users are misbehaving).

A general LIKE protocol is composed of the following algorithms. First a general `Setup` algorithm which, based on a security parameter, returns the public parameters of the protocol, denoted pp. Next comes the key-generation algorithm, one for each type of party. Based on pp, algorithms `UKeyGen`, `OKeyGen` and `AKeyGen` outputs respectively a user, an operator and an authority key pair (PK, SK). Next comes the central algorithm, `AKE`, which takes as parameters two users and two operators, and as input the set of all public keys needed for a protocol run,

and the public parameter `pp`. `AKE` runs a protocol session between the two users and at the end, each users returns a session secret key, and each operator returns a public session state.

The three remaining algorithms are used for verification and opening. The `Verify` algorithm takes as input the public keys of a session's participants, with the associated session state `sst`. It returns 1 if the session correctly runs, and 0 otherwise.
If the `Verify` algorithm returns 1, algorithm `TDGen` and `Open` can run. The first one takes as input the public parameter `pp`, the session state and an authority's secret key, and returns the trapdoor associated to this authority. The second one also takes as input `pp` and the session state, but also the authorities' public key and trapdoor, and thanks to the correctness of the protocol, returns the session key computed by the two users involved in the protocol session run associated to the session state.

THE SECURITY OF LIKE PROTOCOLS. In order to be secure, LIKE protocols must preserve the following properties:

C **Correctness:** Under normal conditions, Alice and Bob obtain the same key. Moreover, this will be the key retrieved by the collaboration of all the authorities by means of lawful interception;

KS **Key-security:** If at least one authority and both users are honest for a given session, that session's key remains indistinguishable from a random key of the same length with respect to an adversary that can control all the remaining parties (including the other authorities and the operator);

NF **Non-Frameability:** The collusion of malicious users, the authorities, and the operator cannot frame an honest user of participating to a session she has not been a party to;

HO **Honest Operator:** If an honest operator forwards the so-called session state of a session it deems correct, then the key recovered by the authorities is the one that the session transcript should have yielded. Thus operators can prove that this protocol is compliant with LI specifications.

CONSTRUCTING LIKE. An initial construction of LIKE was provided in [6]. It relied on standard cryptographic building blocks (pairings, signatures, zero knowledge proofs, and signatures of knowledge), and it was proved secure, provided the Bilinear Decisional Diffie-Hellman problem is intractable, the signature scheme is unforgeable, and the zero-knowledge proofs/signatures are secure.

An improvement to LIKE has been given in [11]. This modification makes LIKE "pairing-free" and enables a unilateral approach for lawful interception. In this more general situation, each user has its own set of authorities, simulating an international-level interception, which allows for opening by each group of authorities without prior negotiations . This new version

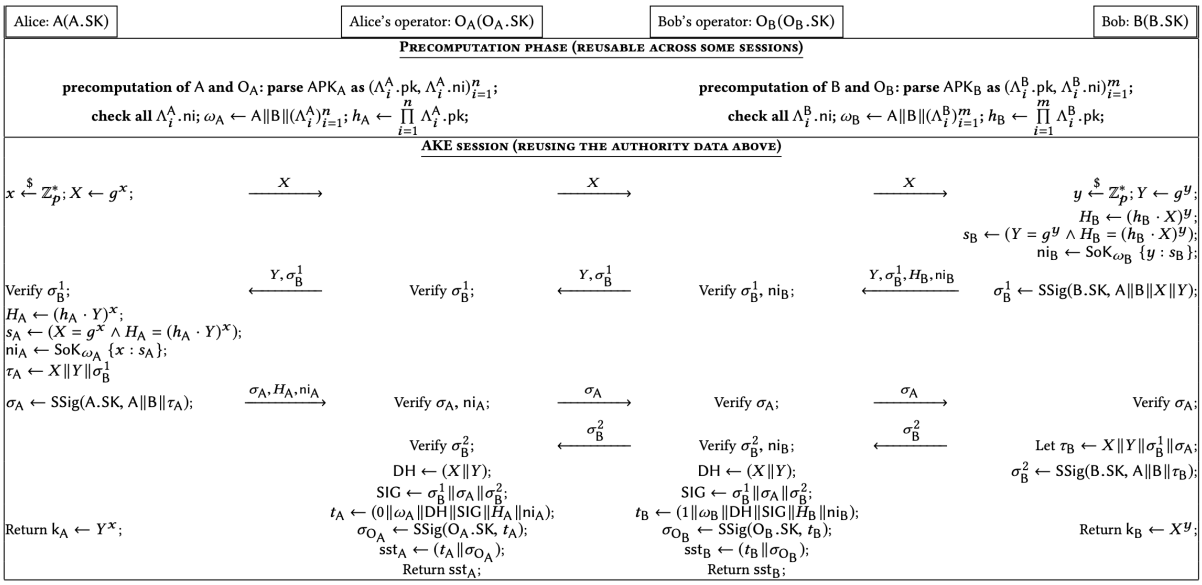

Figure 2.1: The improved LIKE protocol

has been proven secure in the Random Oracle Model (ROM) under the assumption that the Decisional Diffie-Hellman problem is intractable. Here is a high-level description of the latest LIKE version, also depicted in Figure 2.1. On one side, there are Alice A and her operator $\mathsf{O_A}$, and on the other side, Bob B and his operator $\mathsf{O_B}$. Each participant (Alice, Bob, operators, and authorities) is associated with a pair of public and private keys: $(\mathsf{U.PK}, \mathsf{U.SK})$. To prove the legitimacy of an authority, its public key consists of two elements: a Diffie-Hellman element, g^s, and a zero-knowledge proof ensuring that the used s is indeed the private key of that authority. Prior to a key-exchange session between Alice and Bob, a pre-computation stage is set up. During this step, Alice and her operator verify the zero-knowledge proofs of the authorities associated with Alice, initialize ω_A, an element allowing identification of session participants, and compute $\mathsf{h_A}$, the product of Diffie-Hellman elements from Alice's authorities. Bob and his operator do the same for Bob's authorities.

During a LIKE session, assuming the precomputation phase has taken place, Alice starts by choosing $x \leftarrow \$\mathbb{Z}_p^*$, and computes $X = g^x$, which she sends to Bob. Bob does the same with y and $Y = g^y$. He then computes $\mathsf{H_B} = (X\mathsf{h_B})^y$ and authenticates its protocol-compliant response through a signature of knowledge (SoK) $\mathsf{ni_B}$. Bob then transmits Y, $\mathsf{H_B}$, and $\mathsf{ni_B}$. The operator of Bob checks $\mathsf{ni_B}$ and sends Y to Alice. In a similar way, Alice computes $\mathsf{H_A} = (Y\mathsf{h_A})^x$ and makes a SoK $\mathsf{ni_A}$. This proof is then sent to the operator $\mathsf{O_A}$ for verification. Between these exchanges are added three signatures: one by Bob, a second one by Alice, and a third one by Bob again, to mutually authenticate each other and with the operators. If all verifications are successful, Alice and Bob, each on their own side, calculate $\mathsf{k} = g^{xy}$, and the operators return the session state sst. This element contains only public information and allows an authority, first to

verify that the session between Alice and Bob went well, and secondly to compute its trapdoor. This element sst is naturally signed by the operator to ensure security and correctness.

Exceptional LI relies on the construction of the elements h and H. The element H can be viewed as an ElGamal encryption of the shared secret key k. As it includes h (an element involving all authorities), to "decrypt" it, you need to use the trapdoors from all authorities, which will reveal the shared secret key k.

For example, on the $\mathsf{Initiator}$ side, we proceed as follows. For trapdoor generation, based on $\mathsf{sst_I}$, an authority Λ with secret key $\Lambda.\mathsf{SK}$ compute $\Lambda.\mathsf{td} = (g^x)^{\Lambda.\mathsf{SK}}$ where g^x is the ephemeral DH key of the $\mathsf{Initiator}$ (stored in $\mathsf{sst_I}$. Now, with all trapdoors, it is feasible to open the session. Based on $\mathsf{sst_I}$, and given the trapdoor of each authority, we compute :

$$\frac{\mathsf{H_I}}{\prod_{j=1}^{n} \Lambda_j^{\mathsf{I}}.\mathsf{td}} = \frac{(\mathsf{h_I} g^y)^x}{\prod_{j=1}^{n} g^{x\Lambda_j^{\mathsf{I}}.\mathsf{SK}}} = \frac{\left(\prod_{j=1}^{n} g^{\Lambda_j^{\mathsf{I}}.\mathsf{SK}}\right)^x g^{xy}}{\prod_{j=1}^{n} g^{x\Lambda_j^{\mathsf{I}}.\mathsf{SK}}} = \frac{\left(\prod_{j=1}^{n} g^{x\Lambda_j^{\mathsf{I}}.\mathsf{SK}}\right) g^{xy}}{\prod_{j=1}^{n} g^{x\Lambda_j^{\mathsf{I}}.\mathsf{SK}}} = g^{xy}.$$

Security properties. The security properties are proved in the Random Oracle Model, using a Bellare-Rogaway syntax. We consider an environment in which the adversary will be able to interact with honest parties via oracles. Each property is formalized in terms of a security game, played by the adversary against a challenger, which manipulates the honest parties. Each party is associated with a tuple $(\mathsf{SK}, \mathsf{PK})$, namely its long-term private and public key (these key are generated, depending on the type of party, by one of the `UKeyGen`, `OKeyGen` or `AKeyGen` algorithms). Each party is also associated with a corruption flag γ which is raided if the adversary queries the corruption oracle. The users and operators run the authenticated key-exchange protocol in sessions. At each session, each of the four parties generates a new instance of itself. We quantify instances collectively, denoting π_{P}^i the i-th instance generated during the experiment, where P denotes the corresponding party. Each instance stores a number of attributes, basically storing important information related to the session in which it took part. For our security games, we will need to establish a correlation between session states and instances (rather than just between session states and parties, as is done in the verification algorithm). We adopt the same approach as in [6] and require the existence of an auxiliary function $\mathtt{IdentifySession}(\mathsf{sst}, \pi)$, which evaluates to 1 if the given instance has run a session with state sst and 0 otherwise.

Let's provide as short description of the different oracles. In the security games, the adversary will be able to query some or all of the following oracles.

- $\mathtt{Register}(\mathsf{P}, \mathtt{role}, \mathsf{PK}) \rightarrow \mathsf{P.PK}$: Creates a new party adding it to one of the sets USERS, OPS, or AUTH (respectively the sets of users, operators and authorities involved in the security game), depending on the value of `role` (which can be `user`, `operator`, or `authority`). Credentials are also created by using the appropriate key generation algorithm.

- $\texttt{NewSession}(\mathsf{P}, \mathsf{PID}, \mathsf{OID}, \mathsf{AID}) \to \pi^i_{\mathsf{P}}$: Creates a new party or operator instance, with user partner set PID, operator partner set OID, and authority partner set AID.
- $\texttt{Send}(\pi^i_{\mathsf{P}}, m) \to m'$: Sends a message m to instance π^i_{P} and returns m' according to the protocol.
- $\texttt{Reveal}(\pi^i_{\mathsf{P}}) \to \mathsf{k}$: Returns the session key (resp. the session state) if the input instance in an accepting user (resp. operator) instance, and sets that instance's reveal bit to 1.
- $\texttt{Corrupt}(\mathsf{P}) \to \mathsf{P.SK}$: Returns a party's long-term secret key and sets that party's corruption bit to 1: $\mathsf{P}.\gamma = 1$.
- $\texttt{Test}(\pi^i_{\mathsf{P}}) \to \tilde{k}$: This oracle can only be queried once. If the input instance belongs to a user, then, depending on the value of that instance's test bit, this oracle returns either the real key (for $\pi^i_{\mathsf{P}}.b = 0$) or a random key from the same domain otherwise.
- $\texttt{RevealTD}(\mathsf{sst}, \mathsf{A}, \mathsf{B}, \mathsf{O}, (\Lambda_i)_{i=1}^n, l) \to \Lambda_l.\mathsf{td}$: This oracle will reveal the trapdoor that the l-th authority in the input set of authorities would have output for a session sst, if, and only if, the parameters input to this oracle verify for sst (in terms of the algorithm $\texttt{Verify}$).

$\mathsf{Exp}^{\mathsf{KS}}_{\mathsf{LIKE},\mathcal{A}}(\lambda)$:
$\mathsf{pp} \leftarrow \mathsf{Setup}(1^\lambda)$;
$\mathcal{O}_{\mathsf{KS}} \leftarrow \left\{ \begin{array}{l} \mathsf{Register}(\cdot,\cdot,\cdot), \mathsf{Send}(\cdot,\cdot), \\ \mathsf{NewSession}(\cdot,\cdot,\cdot), \\ \mathsf{Reveal}(\cdot), \mathsf{RevealTD}(\cdot,\cdot), \\ \mathsf{Corrupt}(\cdot,\cdot), \mathsf{Test}(\cdot) \end{array} \right\}$;
$(i, \mathsf{P}, \mathsf{d}) \leftarrow \mathcal{A}^{\mathcal{O}_{\mathsf{KS}}}(\lambda, \mathsf{pp})$;
If $\pi^i_{\mathsf{P}}.\mathsf{k}$ is fresh and $\pi^i_{\mathsf{P}}.\mathsf{b} = \mathsf{d}$, return 1;
Else $b' \xleftarrow{\$} \{0,1\}$, return b'.

$\mathsf{Exp}^{\mathsf{NF}}_{\mathsf{LIKE},\mathcal{A}}(\lambda)$:
$\mathsf{pp} \leftarrow \mathsf{Setup}(1^\lambda)$
$\mathcal{O}_{\mathsf{NF}} \leftarrow \left\{ \begin{array}{l} \mathsf{Register}(\cdot,\cdot,\cdot), \mathsf{Send}(\cdot,\cdot), \mathsf{Reveal}(\cdot), \\ \mathsf{NewSession}(\cdot,\cdot,\cdot), \mathsf{RevealTD}(\cdot,\cdot), \mathsf{Corrupt}(\cdot,\cdot) \end{array} \right\}$;
$(\mathsf{sst}, \mathsf{P}) \leftarrow \mathcal{A}^{\mathcal{O}_{\mathsf{NF}}}(\lambda, \mathsf{pp})$;
If $\exists\, (\mathsf{A}, \mathsf{B}) \in \mathsf{USERS}^2$, $n \in \mathbb{N}$, $\mathsf{O} \in \mathsf{OPS}$, $(\Lambda_i)_{i=1}^n \in \mathsf{AUTH}^n$ s.t.:
  $\mathsf{Verify}(\mathsf{pp}, \mathsf{sst}, \mathsf{A.PK}, \mathsf{B.PK}, \mathsf{O.PK}, (\Lambda_i.\mathsf{PK})_{i=1}^n) = 1$;
  $\mathsf{P} \in \{\mathsf{A}, \mathsf{B}\}$;
  $\mathsf{P}.\gamma = 0$;
  $\forall i$, if $\pi^i_{\mathsf{P}} \neq \perp$: $\mathsf{IdentifySession}(\mathsf{sst}, \pi^i_{\mathsf{P}}) = 0$ or $\pi^i_{\mathsf{P}}.\alpha = 0$,
Then return 1,
Else return 0.

$\mathsf{Exp}^{\mathsf{HO}}_{\mathsf{LIKE},\mathcal{A}}(\lambda)$:
$\mathsf{pp} \leftarrow \mathsf{Setup}(1^\lambda)$;
$\mathcal{O}_{\mathsf{HO}} \leftarrow \left\{ \begin{array}{l} \mathsf{Register}(\cdot,\cdot,\cdot), \mathsf{NewSession}(\cdot,\cdot,\cdot), \mathsf{Send}(\cdot,\cdot), \\ \mathsf{Reveal}(\cdot), \mathsf{RevealTD}(\cdot,\cdot), \mathsf{Corrupt}(\cdot,\cdot) \end{array} \right\}$;
$(j, \mathsf{sst}, \mathsf{A}, \mathsf{B}, \mathsf{O}, (\Lambda_i, \Lambda_i.\mathsf{td})_{i=1}^n) \leftarrow \mathcal{A}^{\mathcal{O}_{\mathsf{HO}}}(\lambda, \mathsf{pp})$;
If $\mathsf{O}.\gamma = 1$ then return $\perp$;
If $\mathsf{Verify}(\mathsf{pp}, \mathsf{sst}, \mathsf{A.PK}, \mathsf{B.PK}, \mathsf{O.PK}, (\Lambda_i.\mathsf{PK})_{i=1}^n) = 0$ then return $\perp$;
If $\mathsf{IdentifySession}(\mathsf{sst}, \pi^j_{\mathsf{O}}.\mathsf{sid}) = 0$ then return $\perp$;
$k_* \leftarrow \mathsf{Open}(\mathsf{pp}, \mathsf{sst}, (\Lambda_i.\mathsf{PK})_{i=1}^n, (\Lambda_i.\mathsf{td})_{i=1}^n)$;
Return $(k_*, \pi^j_{\mathsf{O}}, \{\mathsf{P}_i.\mathsf{PK}\}_{i=1}^{q_r})$.

Figure 2.2: LIKE security games

Key-security. In the key-security experiment, the adversary plays the game depicted in Figure 2.2 (left-hand side). It has access to all the oracles presented earlier and eventually outputs a tuple made up of an index i, a party P, and a guess bit d. The adversary wins if d is indeed the test bit associated to instance π^i_{P} (which must be an instance of P), and if that instance is fresh in the sense that $\mathcal{A}$ never learns the instance session key or the long term credentials of P or its partner PID thanks to some oracle (see Definition 6.2 of [11]). The advantage of $\mathcal{A}$ against $\mathsf{Exp}^{\mathsf{KS}}_{\mathsf{LIKE},\mathcal{A}}(\lambda)$ is defined as:

$$\mathsf{Adv}^{\mathsf{KS}}_{\mathsf{LIKE},\mathcal{A}}(\lambda) := \left| \mathbb{P}\left[\mathsf{Exp}^{\mathsf{KS}}_{\mathsf{LIKE},\mathcal{A}}(\lambda) = 1\right] - \frac{1}{2} \right|$$

We call the LIKE scheme key-secure if all PPT adversaries have at most a negligible advantage to win.

Non-frameability. In the non-frameability game, $\mathcal{A}$ has access to all but the testing oracle, and it eventually outputs a session-state/party tuple. The adversary wins if party P never took part in (or never completed) the session that yielded sst. This is captured by the experiment in Figure 2.2 (center). We define the advantage of $\mathcal{A}$ as:

$$\mathsf{Adv}^{\mathsf{NF}}_{\mathsf{LIKE},\mathcal{A}}(\lambda) = \mathbb{P}\left[\mathsf{Exp}^{\mathsf{NF}}_{\mathsf{LIKE},\mathcal{A}}(\lambda) = 1\right].$$

A LIKE scheme is non-frameable if all PPT adversaries have at most a negligible advantage to win the NF game.

Honest operator. In the Honest operator game, the adversary wants to make the lawful-interception process performed on a specific completed session somehow fail (i.e., retrieve a different key than should be recovered, or not to retrieve a key at all). The definition depends on a simulator called the extractor `Extract`, whose job is to retrieve, from a session state, the key that Alice and Bob should have computed (from a practical standpoint, this is an unbounded algorithm that brute-forces the Diffie–Hellman problem). Note that, since in this game Alice and Bob are malicious, they cannot be compelled to compute – or in fact use – the key that is yielded by our scheme; however, we can compel them to run the protocol correctly to completion. This is the main task of the operators, who have to check all the signatures, as well as the proofs of well-formedness of $\mathsf{H_A}$ and $\mathsf{H_B}$ provided by the endpoints. A LIKE scheme is honest-operator secure if there exists an extractor that makes the adversary's advantage in the honest-operator game (right-hand side of Figure 2.2) negligible as a function of λ. The advantage is defined as:

$$\mathsf{Adv}^{\mathsf{HO}}_{\mathsf{LIKE},\mathcal{A}}(\lambda) = \mathbb{P}\left[(\mathsf{k}_*, \pi_{\mathsf{O}}, \mathsf{PPK}) \leftarrow \mathsf{Exp}^{\mathsf{HO}}_{\mathsf{LIKE},\mathcal{A}}(\lambda); \mathsf{k} \leftarrow \mathtt{Extract}(\pi_{\mathsf{O}}, \mathsf{PPK}) : \mathsf{k} \neq \perp \wedge \mathsf{k}_* \neq \perp \wedge \mathsf{k} \neq \mathsf{k}_*\right]$$

where PPK is the set of all the public keys used in the session.

This leads to the following security theorem.

Theorem 1. *Assuming that we instantiate the LIKE protocol with an* $\mathsf{EUF-CMA}$*-secure signature scheme, then the LIKE scheme:*

- *is non-frameable. Moreover, for all PPT* $\mathcal{A}$*, making at most* q_{r} *queries to* `Register`*:*

$$\mathsf{Adv}^{\mathsf{NF}}_{\mathsf{LIKE},\mathcal{A}}(\lambda) \leq q_{\mathsf{r}}\mathsf{Adv}^{\mathsf{EUF-CMA}}_{\mathsf{DS}}(\lambda).$$

- *is honest-operator if, additionally, the proofs and signatures of knowledge are zero-knowledge and extractable. Moreover, for all PPT adversaries* $\mathcal{A}$ *doing at most* q_{r} *queries to the oracle* `Register` *and denoting* $\epsilon_{\mathsf{NIPoK}}$ *and* ϵ_{SoK} *the failure probability of extractor associated*

to NIPoK *and* SoK *respectively, we have:*

$$\mathsf{Adv}^{\mathsf{HO}}_{\mathsf{LIKE},\mathcal{A}}(\lambda) \leq q_{\mathsf{r}} \left(\epsilon_{\mathsf{NIPoK}}(\lambda) + \epsilon_{\mathsf{SoK}}(\lambda) + \mathsf{Adv}^{\mathsf{EUF-CMA}}_{\mathsf{DS}}(\lambda) \right).$$

- *is key-secure if in addition the proofs and signatures of knowledges are extractable and zero-knowledge, and the DDH assumption holds. Moreover for all PPT adversaries $\mathcal{A}$ making at most q_{r} (resp. $q_{\mathsf{ns}}, q_{\mathsf{s}}$ and q_{t}) queries to* `Register` *(resp.* `NewSession`*,* `Send` *and* `RevealTD`*):*

$$\mathsf{Adv}^{\mathsf{KS}}_{\mathsf{LIKE},\mathcal{A}}(\lambda) \leq q_{\mathsf{s}}^2 + q_{\mathsf{ns}} q_{\mathsf{r}}^2 \Big(\mathsf{Adv}^{\mathsf{EUF-CMA}}_{\mathsf{DS}}(\lambda) + q_{\mathsf{ns}} q_{\mathsf{r}}^2 \Big((2q_{\mathsf{t}} + q_{\mathsf{s}}) \epsilon_{\mathsf{SoK}}(\lambda) + q_{\mathsf{r}} \epsilon_{\mathsf{NIPoK}}(\lambda) + 3\mathsf{Adv}^{\mathsf{DDH}}(\lambda) \Big) \Big).$$

2.4 Towards privacy-preserving LI in future mobile networks

The LIKE approach seems promising to achieving privacy-preserving fine-grained Lawful Interception in 5G and future mobile networks. However, several challenges render LIKE somewhat incompatible with current (and potentially future) mobile networks.

Challenge 1: Current secure-channel establishment (AKA and Handovers).

The two current instantiations of LIKE are based on public-key cryptography, and notably the Diffie-Hellman key-exchange. This is not the case for the staple protocols provided for secure-channel establishment in mobile networks, such as AKA or the Handovers protocols. Indeed, deploying an extensive Public-Key Infrastructure (PKI) has so far been impossible in mobile contexts, as maintaining the PKI would be costly and require trusted elements, such as USIM cards, to be able to frequently update keys and certificates.

While 5G networks make a partial step in the direction of public-key cryptography (encrypting the long-term identifier of the mobile user), its protocols are far from following a signed-Diffie-Hellman structure. It remains an open challenge to securely compose existing mobile-network protocols and the LIKE approach.

Challenge 2: Scale. LIKE remains a small-scale protocol, which has never been tested in practice. As one of the requirements of Lawful Interception is efficiency and correctness, it is paramount to understand both the complexity of providing LI in large-scale networks, and the flexibility of the approach with respect to different legal setups and requirements.

Challenge 3: Future networks and the quantum threat. Finally, note that while current mobile networks operate with protocols which are not entirely quantum-resistant, future networks might require the use of post-quantum cryptography. While LIKE is a primitive that can exist in a post-quantum world, its two instantiations employ classical cryptography only. A challenge in future networks is addressing the quantum threat in lawful interception.

Conclusion

EDHOC is a new standardized authenticated key exchange protocol targeting Internet-of-Things use cases. It was developed from 2019 to 2023 by the LAKE working group of the IETF. EDHOC was formally analyzed by the research community during the standardization process. This deliverable outlines the main design choices of EDHOC and surveys the state of the art on the protocol, including its Lawful Interception.

Lawful Interception is a controversial, but compulsory aspect of mobile communications. It intuitively requires Mobile Network Operators (MNOs) to exclusively deploy secure channel-establishment protocols that can be intercepted by the authorities (upon presenting a lawful warrant). Lawful Interception must be promptly answered by the MNO, for all the protocol sessions concerned by the warrant. LI requirements are a key reason why mobile secure-communications are never End-to-End Secure – rather, the MNO essentially runs a Person-in-the-Middle attack, becoming a legitimate intermediary endpoint in the conversation and learning the contents of the conversations.

While it might seem that Lawful Interception is incompatible with privacy-preservation, the Lawful Interception Key-Exchange (LIKE) approach seems to provide a balance between the two requirements. Indeed, while the LIKE approach cannot be directly applied by composition to the existing 5G protocol stack, its generic structure renders its use in 5G and future networks possible and promising.

Bibliography

[1] 3GPP. Lawful interception architecture and functions. `https://portal.3gpp.org/desktopmodules/Specifications/SpecificationDetails.aspx?specificationId=3182`, 2018.

[2] 3GPP. Lawful interception requirements. `https://portal.3gpp.org/desktopmodules/Specifications/SpecificationDetails.aspx?specificationId=3181`, 2018.

[3] 3GPP. *TS 33.106 3rd Generation Partnership Project; Technical Specification Group Services and System Aspects; 3G security; Lawful interception requirements (Release 15)*, 6 2018.

[4] 3GPP. Protocols and procedures for lawful interception. `https://portal.3gpp.org/desktopmodules/Specifications/SpecificationDetails.aspx?specificationId=3183`, 2019.

[5] H. Abelson, R. Anderson, S. M. Bellovin, J. Benaloh, M. Blaze, W. Diffie, J. Gilmore, M. Green, S. Landau, P. G. Neumann, R. L. Rivest, J. I. Schiller, B. Schneier, M. A. Specter, and D. J. Weitzner. Keys under doormats. *Comms. of the ACM*, 58(10):24–26, 2015.

[6] G. Arfaoui, O. Blazy, X. Bultel, P.-A. Fouque, T. Jacques, A. Nedelcu, and C. Onete. How to (legally) keep secrets from mobile operators. In *Proceedings of ESORICS*, pages 23–43, 2021.

[7] A. Azfar. Implementation and Performance of Threshold Cryptography for Multiple Escrow Agents in VoIP. In *Proceedings of SPIT/IPC*, pages 143–150, 2011.

[8] M. Bellare and S. Goldwasser. Verifiable partial key escrow. In *Proceedings of ACM CCS*, pages 78–91. ACM, 1997.

[9] M. Bellare and R. L. Rivest. Translucent Cryptography - An Alternative to Key Escrow, and Its Implementation via Fractional Oblivious Transfer. *J. Cryptology*, 12(2):117–139, 1999.

[10] M. Bellare and P. Rogaway. The Security of Triple Encryption and a Framework for Code-Based Game-Playing Proofs. In *International Conference on the Theory and Application of Cryptographic Techniques (Eurocrypt)*, Saint Petersburg, Russia, 28 May – 1 June 2006.

[11] X. Bultel and C. Onete. Pairing-free secure-channel establishment in mobile networks with fine-grained lawful interception. In *Proceedings of ACM SAC*, page 968–970, 2022.

[12] L. Chen, D. Gollmann, and C. J. Mitchell. Key escrow in mutually mistrusting domains. In *Proceedings of Security Protocols*, pages 139–153, 1996.

[13] M. Chen. Escrowable identity-based authenticated key agreement in the standard model. In *Chinese Electronics Journal*, volume 43, pages 1954–1962, 10 2015.

[14] G. E. Coalition. Joint statement on the dangers of the may 2024 council of the EU comrpomise proposal on EU CSAM. `https://www.globalencryption.org/2024/05/joint-statement-on-the-dangers-of-the-may-2024-council-of-the-eu-compromise-proposal-on-` 2024.

[15] J. Comey and (FBI). Going dark: are technology, privacy, and public safety on a collision course?, 2014.

[16] B. Cottier and D. Pointcheval. Security Analysis of Improved EDHOC Protocol. In *International Symposium on Foundations and Practice of Security (FPS)*, Ottawa, ON, Canada, 2022.

[17] E. Council. Resolution on security through encryption and security despite encryption. `https://data.consilium.europa.eu/doc/document/ST-13084-2020-REV-1/en/pdf`, 2020.

[18] D. E. Denning and D. K. Branstad. A taxonomy for key escrow encryption systems. *Communications of the ACM*, 39(3), 1996.

[19] Y. Desmedt. Abuses in Cryptography and How to Fight Them. In *CRYPTO '88*, volume 403 of *LNCS*. Springer, 1988.

[20] EU. Draft council resolution on encryption - security through encryption and security despite encryption, 2020.

[21] Europol. Europol and the european commission inaugurate new decryption platform to tackle the challenge of encrypted material for law enforcement investigations.

[22] FairTrials. Short update: Police in germany defend the use of contact tracing for criminal investigations. `https://www.fairtrials.org/news/short-update-police-germany-defend-use-contact-tracing-criminal-investigations`, 2020.

[23] Q. Fan, M. Zhang, and Y. Zhang. Key Escrow Scheme with the Cooperation Mechanism of Multiple Escrow Agents. 2012.

[24] G. Fedrecheski, M. Vučinić, and T. Watteyne. Performance Comparison of EDHOC and DTLS 1.3 in Internet-of-Things Environments. In *IEEE Wireless Communications and Networking Conference (WCNC)*, Dubai, United Arab Emirates, 21–24 April 2024.

[25] L. Ferreira. Computational Security Analysis of the Full EDHOC Protocol. In *Cryptographers' Track at the RSA Conference (CT-RSA)*, San Francisco, CA, USA, May 2024.

[26] L. Franceschi-Bicchierai. The 10 biggest revelations from edward snowden's leaks. `https://mashable.com/2014/06/05/edward-snowden-revelations/?europe=true`, 2014.

[27] F. Günther and M. I. Tshibumbu Mukendi. Careful with MAc-then-SIGn: A Computational Analysis of the EDHOC Lightweight Authenticated Key Exchange Protocol. In *IEEE European Symposium on Security and Privacy (EuroS&P)*, Delft, The Netherlands, July 2023.

[28] C. Jacomme, E. Klein, S. Kremer, and M. Racouchot. A Comprehensive, Formal and Automated Analysis of the EDHOC Protocol. In *USENIX Security Symposium (USENIX)*, Anaheim, CA, USA, August 2023.

[29] L. Kahney. The fbi wanted a back door to the iphone. tim cook said no, 2019.

[30] J. Kilian and F. T. Leighton. Fair Cryptosystems, Revisited: A Rigorous Approach to Key-Escrow (Extended Abstract). In *Advances in cryptology – CRYPTO*, volume 963 of *LNCS*, pages 208–221. Springer, 1995.

[31] J. Kim, D. G. Duguma, S. Lee, B. Kim, J. Lim, and I. You. Scrutinizing the Vulnerability of Ephemeral Diffie–Hellman over COSE (EDHOC) for IoT Environment Using Formal Approaches. *Mobile Information Systems*, 2021.

[32] Y. Long, Z. Cao, and K. Chen. A dynamic threshold commercial key escrow scheme based on conic. *Appl. Math. Comput.*, 171(2):972–982, 2005.

[33] Y. Long, K. Chen, and S. Liu. Adaptive Chosen Ciphertext Secure Threshold Key Escrow Scheme from Pairing. *Informatica, Lith. Acad. Sci.*, 17(4):519–534, 2006.

[34] K. M. Martin. Increasing Efficiency of International Key Escrow in Mutually Mistrusting Domains. In *Cryptography and Coding*, volume 1355 of *LNCS*, pages 221–232. Springer, 1997.

[35] J. P. Mattsson, F. Palombini, and M. Vučinić. Comparison of CoAP Security Protocols, January 2024. draft-ietf-iotops-security-protocol-comparison-06 (Work-in-Progress).

[36] S. Micali. Fair Public-Key Cryptosystems. In *CRYPTO '92*, volume 740 of *LNCS*. Springer, 1992.

[37] I. Mironov and N. Stephens-Davidowitz. Cryptographic Reverse Firewalls. In *EUROCRYPT*, volume 9057, pages 657–686. Springer, 2015.

[38] C. Museum. Clipper chip.

[39] L. Ni, G. Chen, and J. Li. Escrowable identity-based authenticated key agreement protocol with strong security. *Comput. Math. Appl.*, 65(9):1339–1349, 2013.

[40] K. Norrman, V. Sundararajan, and A. Bruni. Formal Analysis of EDHOC Key Establishment for Constrained IoT Devices. *arXiv*, 2020.

[41] T. Perrin. The Noise Protocol Framework. https://noiseprotocol.org/noise.html, July 2018. (visited 30 May 2024).

[42] . scientists and researchers from 36 countries. Open letter on the position of scientists and researchers on the updated version of the EU's proposed Child Sexual Abuse Regulation. `https://homes.esat.kuleuven.be/~preneel/Open_letter_CSAR_aug24_still_unacceptable.pdf`, 2024.

[43] A. Shamir. Partial key escrow: A new approach to software key escrow. Presented at Key Escrow Conference, 1995.

[44] A. Shamir. Identity-Based Cryptosystems and Signature Schemes. In *CRYPTO*, pages 47–53, 1984.

[45] UN. Universal Declaration of Human Rights. `https://www.un.org/en/universal-declaration-human-rights/`, 1948.

[46] UN. Special rapporteur on privacy. `https://www.ohchr.org/en/special-procedures/`, 2021.

[47] M. Vučinić, G. Selander, J. P. Mattsson, and D. Garcia-Carillo. Requirements for a Lightweight AKE for OSCORE, June 2020. draft-ietf-lake-reqs-04 (Work-in-Progress).

[48] M. Vučinić, G. Selander, J. P. Mattsson, and T. Watteyne. Lightweight Authenticated Key Exchange With EDHOC. *IEEE Computer*, 55(4):94–100, 2022.

[49] Z. Wang, Z. Ma, S. Luo, and H. Gao. Key escrow protocol based on a tripartite authenticated key agreement and threshold cryptography. *IEEE Access*, 7:149080–149096, 2019.

[50] C. V. Wright and M. Varia. Crypto crumple zones: Enabling limited access without mass surveillance. In *Proceedings of EuroS&P 2018*. IEEE, 2018.

[51] A. L. Young and M. Yung. Kleptography from Standard Assumptions and Applications. In *Proceedings of SCN*, pages 271–290, 2010.